

Technology Services Requisition (TRex) Smart Everything (SE)

Software as a Solution (SaaS)



Requirements Analysis Report

Version 1.1

<June 23, 2026>

1. Executive Summary

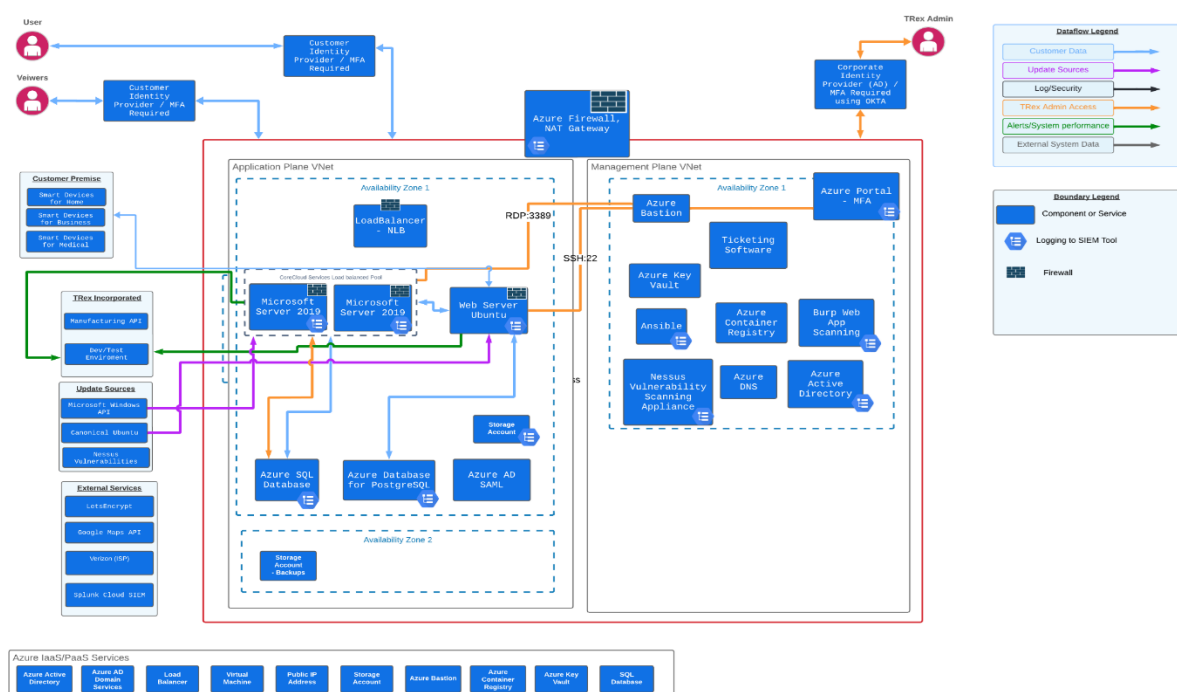
TRex develops smart devices to be used for homes, businesses, and in the medical industry. These smart devices include alarm systems, appliances, and human-worn devices. These devices collect personable identifiable information (PII), protected health information (PHI), credit card information, device, and security information, and contain other sensitive data. The devices can be configured to be linked to first responders, family members, or any authorized users a business and/or the owner of the device chooses.

The devices that deploy Trex's software are configured to communicate with the Trex's Smart Everything (Trex SE) Software as a Service (SaaS) platform that is hosted on the Azure Commercial Cloud Infrastructure as a Service (IaaS) platform. All Trex administrators log into the management plane of the Trex IoT SE using Trex's active directory configured for

multifactor authentication (MFA) using OKTA. Customers must use MFA and must provide their own identity provider (if applicable). All customer users will be configured to use MFA to gain access to the device as well as Trex SE, of their choice, no exceptions. FIPS 140-2 validated encryption is used throughout the environment and all events from each host within the environment are logged and sent to Splunk. Within the Trex SE platform, all technology is updated automatically using advanced programmable interfaces (APIs). The home and business devices will use their own internet service provider (ISP); however, due to the sensitive nature of the medical devices and their purposes, Trex will utilize Verizon ISP for internet connectivity with these devices. No data leaves the United States borders per service level agreements (SLA).

There are several dataflows within the Trex SE environment including customer data, update sources, logging/security, Trex administration, alerts, and external system data. The two main dataflows are the customer to devices, devices to Trex SE, and management plane to application plane. Customers interact with their devices through an ISP provider. Although customers can access some offline functionality, there must be an active and stable internet connection for the device to be able to pull and push accurate and current information from TRex SE. Smart devices respond to customer's voices, fingerprints, and in the case of medical devices, physical attributes such as heart rate, blood sugar levels, blood pressure, etc. This information, once collected from the customer, is communicated with TRex SE through an encrypted tunnel using FIPS 140-2 validated encryption. TRex SE analyzes the data sent from the device to either warn the user about potentially harmful activities or statistics, or if a certain range will prompt the user to dial 911 immediately, and for some medical devices, the device will use E911 and dial for the customer. For home and business devices, TRex SE may make recommendations based on the customer's use of the device as well as send health statistics of the device itself. For medical devices, TRex SE performs trend analysis to properly baseline the health of the individual using the device. This information is communicated to the user of the device but can also be communicated to authorized users, known as Viewers, of the information that the device produces. TRex admins are responsible for managing the TRex SE application. They perform several security and continuous monitoring activities.

2. System Diagram



3. Cloud Controls Matrix Requirements

3.1 TVM: Threat & Vulnerability Management

TVM-04: Detection Updates

- TRex should define, implement and evaluate processes, procedures and technical measures to update detection tools, threat signatures, and indicators of compromise on a weekly, or more frequent basis.
- Although TRex uses centralized logging and continuous monitoring to identify suspicious activity within the TRex SE environment, the organization does not fully meet the requirements for TVM-04. The vulnerability assessment identified several outdated software components and security-related vulnerabilities, including issues affecting Splunk, Log4j, ImageMagick, and other applications. These findings indicate that TRex may not have a formal process in place to consistently update detection tools, threat signatures, and indicators of compromise. Without regularly updated detection capabilities, new threats and attack techniques may go undetected, increasing the risk of unauthorized access, system compromise, and disruption of services. Therefore, TRex should establish documented procedures to ensure detection content is reviewed, updated, and validated on a recurring basis.

TVM-05: External Library Vulnerabilities

- TRex should define, implement and evaluate processes, procedures and technical measures to identify updates for applications which use third party or open-source libraries according to the organization's vulnerability management policy.
- Although TRex utilizes automated updates and vulnerability management practices within portions of the TRex SE environment, TRex does not fully meet the requirements of TVM-05. Unit 1 vulnerability assessments identified vulnerabilities associated with third-party and open-source software components, including Apache Log4j, Python Brotli, and ImageMagick.

TVM-09: Vulnerability Management Reporting

- TRex should define and implement a process for tracking and reporting vulnerability identification and remediation activities that include stakeholder notification.
- Although TRex performs vulnerability assessments and security monitoring activities within the TRex SE environment, TRex does not fully meet the requirements of TVM-09. Unit 1 vulnerability assessments identified multiple vulnerabilities affecting applications, software libraries, encryption implementations, and supporting infrastructure components.

3.2: CEK: Cryptography, Encryption & Key Management

CEK-09: Encryption and Key Management Audit

- TRex should audit encryption and key management systems, policies, and processes with a frequency that is proportional to the risk exposure of the system with audit occurring preferably continuously but at least annually and after any security event.
- Although TRex utilizes FIPS 140-2 validated encryption throughout the TRex SE environment, TRex does not fully meet the requirements of auditing encryption and key management systems, policies, and processes. My previous project in unit 1 and 3 identified self-signed and untrusted SSL certificates. These findings indicate that TRex lacks sufficient evidence of a formal audit process to regularly review certificate configurations, encryption implementations, key management practices, and compliance with established encryption standards.

CEK-01: Encryption and Key Management Policy and Procedures

- TRex should establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for Cryptography, Encryption and Key Management. Review and update the policies and procedures at least annually.
- Although TRex utilizes encryption technologies and FIPS 140-2 validated cryptographic mechanisms to protect sensitive information within the TRex SE environment, TRex does

not fully meet the requirements of CEK-01. Unit 1 vulnerability assessments identified self-signed and untrusted SSL certificates, while Unit 3 threat modeling identified risks associated with interception of sensitive data and impersonation of trusted services.

CEK-03: Data Encryption

- TRex should provide cryptographic protection to data at-rest and in-transit, using cryptographic libraries certified to approved standards.
- Although TRex utilizes encryption technologies and FIPS 140-2 validated cryptographic mechanisms to protect sensitive information within the TRex SE environment, TRex does not fully meet the requirements of CEK-03. Unit 1 vulnerability assessments identified self-signed certificates, untrusted SSL certificates, and weaknesses related to SSL/TLS configurations. Unit 3 threat modeling further identified the risk that attackers could intercept sensitive communications, impersonate trusted services, or gain unauthorized access to protected information.

3.3: IAM: Identity & Access Management

IAM-14: Strong Authentication

- TRex should define, implement and evaluate processes, procedures and technical measures for authenticating access to systems, application and data assets, including multifactor authentication for at least privileged user and sensitive data access. Adopt digital certificates or alternatives which achieve an equivalent level of security for system identities.
- Although TRex requires MFA for administrators and customers accessing the TRex SE platform, the organization does not fully meet the requirements of IAM-14. The vulnerability assessment identified weaknesses related to authentication controls, including an OpenVPN service that did not enforce strong authentication mechanisms. In addition, the threat modeling exercise identified the risk of attackers bypassing authentication controls and gaining unauthorized access to systems and sensitive information.

IAM-05: Least Privilege

- TRex should employ the least privilege principle when implementing information system access.
- Although TRex utilizes multifactor authentication and access controls within the TRex SE environment, TRex does not fully meet the requirements of IAM-05. Unit 3 threat modeling identified risks associated with unauthorized access to systems, applications, and sensitive information. Additionally, Unit 1 vulnerability assessments identified weaknesses that could potentially be exploited by attackers to gain access to resources beyond their authorized permissions

IAM-16: Authorization Mechanisms

- TRex should define, implement and evaluate processes, procedures and technical measures to verify access to data and system functions is authorized.
- Although TRex utilizes multifactor authentication and access controls within the TRex SE environment, TRex does not fully meet the requirements of IAM-16. Unit 3 threat modeling identified risks associated with unauthorized access to systems, applications, and sensitive information.

3.4: AIS: Application & Interface Security

AIS-07: Application Vulnerability Remediation

- TRex should define and implement a process to remediate application security vulnerabilities, automating remediation when possible.
- Although TRex performs security monitoring and applies updates to portions of the TRex SE environment, TRex does not fully meet the requirements of AIS-07. Previous assignments identified several application related vulnerabilities, including Log4j, ImageMagick, CGI, Directory Traversal, and outdated software components.

AIS-04: Secure Application Design and Development

- TRex should define and implement a SDLC process for application design, development, deployment, and operation in accordance with security requirements defined by the organization.
- Although TRex develops and maintains applications within the TRex SE environment, TRex does not fully meet the requirements of AIS-04. Unit 1 vulnerability assessments identified application-related vulnerabilities, including Log4j, Directory Traversal, CGI vulnerabilities, and ImageMagick vulnerabilities

AIS-05: Automated Application Security Testing

- TRex should implement a testing strategy, including criteria for acceptance of new information systems, upgrades and new versions, which provides application security assurance and maintains compliance while enabling organizational speed of delivery goals. Automate when applicable and possible.
- Although TRex performs vulnerability assessments and security monitoring activities within the TRex SE environment, TRex does not fully meet the requirements of AIS-05. Unit 1 vulnerability assessments identified several application-related vulnerabilities, including Log4j, Directory Traversal, CGI vulnerabilities, and ImageMagick vulnerabilities

3.5. LOG: Logging and Monitoring

LOG-03: Security Monitoring and Alerting

- TRex should identify and monitor security-related events within applications and the underlying infrastructure. Define and implement a system to generate alerts to responsible stakeholders based on such events and corresponding metrics.
- Although TRex utilizes Splunk and continuous monitoring capabilities within the TRex SE environment, TRex does not fully meet the requirements of LOG-03. Vulnerability assessments from previous assignment identified vulnerabilities affecting Splunk and other critical applications.

LOG-05: Audit Logs Monitoring and Response

- TRex should monitor security audit logs to detect activity outside of typical or expected patterns. Establish and follow a defined process to review and take appropriate and timely actions on detected anomalies.
- Although TRex utilizes centralized logging and monitoring capabilities through Splunk within the TRex SE environment, TRex does not fully meet the requirements of LOG-05. Unit 1 vulnerability assessments identified vulnerabilities affecting Splunk and other critical applications, while Unit 3 threat modeling identified risks associated with unauthorized access, authentication bypass, malicious activity, and exploitation of application vulnerabilities.

LOG-02: Audit Logs Protection

- TRex should define, implement and evaluate processes, procedures and technical measures to ensure the security and retention of audit logs.
- Although TRex utilizes centralized logging through Splunk and maintains security monitoring capabilities within the TRex SE environment, TRex does not fully meet the requirements of LOG-02. Unit 1 vulnerability assessments identified vulnerabilities affecting Splunk and other critical systems, while Unit 3 threat modeling identified risks associated with unauthorized access, malicious activity, and attempts to compromise sensitive information.

4. Recommendations

4.1 Recommendation

TVM-04

- TRex must establish processes and procedures to ensure detection tools, threat signatures, and indicators of compromise (IOCs) are updated on a weekly, or more frequent basis.
 - TRex can accomplish this by first implementing a policy that requires all security detection technologies to receive regular updates and reviews. TRex should establish a formal Threat and Vulnerability Management program that defines roles and responsibilities for maintaining detection tools, validating threat intelligence feeds, and updating indicators of compromise.

4.2 Recommendation

TVM-05

- TRex must establish and maintain a formal process for identifying, monitoring, and remediating vulnerabilities associated with third-party and open-source software libraries used within the TRex SE environment.
 - TRex can accomplish this by first implementing a policy that requires all third-party and open-source software components to be inventoried, monitored, and reviewed for known vulnerabilities

4.3 Recommendation

TVM-09

- TRex must establish and maintain a formal vulnerability management reporting process to ensure identified vulnerabilities are tracked, communicated, and remediated in a timely manner.
 - TRex can accomplish this by first implementing a policy that requires all identified vulnerabilities to be documented, assigned a risk rating, and reported to appropriate stakeholders. TRex should establish procedures for tracking vulnerability remediation activities, assigning ownership, monitoring remediation progress, and communicating status updates to management and system owners.

4.4 Recommendation

- CEK-09
 - TRex must establish and maintain a formal audit process for encryption and key management systems, policies, and procedures to ensure encryption controls remain effective and compliant with organizational and regulatory requirements.
 - TRex can accomplish this by first implementing a policy that requires periodic reviews of all encryption and key management activities within the TRex SE environment. TRex should establish an encryption and key management audit program that includes reviewing SSL/TLS certificates, validating certificate

authorities, assessing encryption configurations, evaluating key management practices, and documenting audit results.

4.5 Recommendation

- CEK-01
 - TRex must establish and maintain formal encryption and key management policies and procedures to ensure sensitive information is consistently protected throughout the TRex SE environment.
 - TRex can accomplish this by first implementing a policy that defines encryption requirements for data at rest and data in transit, approved cryptographic standards, certificate management procedures, and key management responsibilities

4.6 Recommendation

- CEK-03
 - TRex must ensure that all sensitive data is protected through approved encryption mechanisms while stored and during transmission across the TRex SE environment.
 - TRex can accomplish this by first implementing a policy that requires the use of approved encryption standards for protecting data at rest and data in transit. TRex should establish procedures for validating SSL/TLS configurations, replacing self-signed or untrusted certificates, enforcing the use of trusted certificate authorities, and regularly reviewing encryption settings.

4.7 Recommendation

- IAM-14
 - TRex must ensure strong authentication controls are consistently implemented across all systems, applications, and remote access services.
 - TRex should also establish procedures for regularly reviewing authentication settings and verifying that strong authentication requirements are enforced throughout the environment.

4.8 Recommendation

- IAM-05
 - TRex must implement and maintain the principle of least privilege across all systems, applications, and data resources within the TRex SE environment.
 - TRex can accomplish this by first implementing a policy that requires access permissions to be assigned based on business need and job responsibilities.

4.9 Recommendation

- IAM-16

- TRex must establish and maintain authorization mechanisms that ensure access to systems, applications, and sensitive data is granted only to authorized users based on business and security requirements.
 - TRex can accomplish this by first implementing a policy that defines authorization requirements for all users, applications, and system functions. TRex should establish procedures for assigning role-based access permissions, approving access requests, reviewing authorization settings, and removing unauthorized access when identified

4.10 Recommendation

- AIS-07
 - TRex must establish and maintain a formal application vulnerability remediation process to ensure application security vulnerabilities are identified, prioritized, remediated, and validated in a timely manner.
 - TRex can accomplish this by first implementing a policy that requires application vulnerabilities to be assessed, categorized by risk level, assigned to responsible personnel, and remediated within defined timeframes.

4.11 Recommendation

- AIS-04
 - TRex must establish and maintain a Secure Software Development Lifecycle (SDLC) process to ensure security requirements are incorporated throughout application design, development, testing, deployment, and operational activities.
 - TRex can accomplish this by first implementing a policy that requires security to be integrated into every phase of the software development lifecycle. TRex should establish procedures for secure coding practices, security requirements analysis, threat modeling, code reviews, vulnerability assessments, and security testing prior to deployment.

4.12 Recommendation

- AIS-05
 - TRex must establish and maintain an automated application security testing program to identify and remediate vulnerabilities throughout the software development lifecycle
 - TRex can accomplish this by first implementing a policy that requires security testing to be performed on all new applications, software updates, and system changes before deployment. TRex should establish procedures for conducting automated security testing activities, including static application security testing (SAST), dynamic application security testing (DAST), dependency scanning, and vulnerability assessments.

4.13 Recommendation

- LOG-03
 - TRex must establish and maintain a comprehensive security monitoring and alerting capability to detect, analyze, and respond to security-related events across the TRex SE environment.
 - TRex can accomplish this by first implementing a policy that defines monitoring requirements, alert thresholds, escalation procedures, and responsibilities for responding to security events. TRex should establish documented procedures for monitoring applications, network devices, cloud resources, and security tools to identify suspicious activity and potential threats.

4.14 Recommendation

- LOG-05
 - TRex must establish and maintain a formal audit log monitoring and response process to ensure suspicious activities and security events are identified, investigated, and addressed in a timely manner
 - TRex can accomplish this by first implementing a policy that defines requirements for audit log review, anomaly detection, incident escalation, and response activities. TRex should establish procedures for continuously monitoring security logs, investigating unusual events, documenting findings, and tracking corrective actions.

4.15 Recommendation

- LOG-02
 - TRex must establish and maintain controls to protect audit logs from unauthorized access, modification, deletion, and disclosure.
 - TRex can accomplish this by first implementing a policy that defines requirements for audit log protection, retention, access control, and storage. TRex should establish procedures for restricting access to audit logs based on job responsibilities, maintaining log backups, and ensuring logs are stored in secure repositories.

Controls Chosen

AIS: Application & Interface Security

CEK: Cryptography, Encryption & Key Management

IAM: Identity & Access Management

LOG: Logging and Monitoring

TVM: Threat & Vulnerability Management